

TARA Tool — User Guide

Step-by-step instructions for creating, reviewing and exporting an analysis

Edition: 17 September 2026 · Language: English

This guide describes the current tool, including asset-linked risks, lifecycle phases, security goals, residual assessment, security-level settings and the CRA Documentation Checklist. It uses the English interface labels. The **EN/DE** switch changes the display language.

Follow the steps in order for a new analysis. Return to earlier steps whenever the product, assumptions, damage ratings or attack paths change. Examples illustrate how to enter information; adapt the decisions to your company and operating context.

Contents

- | | |
|---|---|
| 1. Start and protect your work | 9. Evaluate residual risks |
| 2. Define the scope in Overview | 10. Review CRA documentation |
| 3. Agree assessment settings | 11. Use the Parameters reference |
| 4. Register and evaluate assets | 12. Save versions and export deliverables |
| 5. Rate damage scenarios and explain every cell | 13. Worked example |
| 6. Create risks and attack paths | 14. Troubleshooting and final review |
| 7. Assign lifecycle phases | 15. Maintain the guidance |
| 8. Define security goals | |

1. Start and protect your work

1. Open the supplied `index.html` in a modern browser, or open your organisation's hosted copy of the tool.
2. Choose **EN** or **DE** in the top bar. Use the sun/moon switch for light or dark mode.
3. Click **New**, enter an analysis name and click **Create**. To reuse an existing analysis, expand **Copy** and select the source before creating the new analysis. Review copied content before relying on it.
4. Check the analysis selector in the top bar. All subsequent work applies to the selected analysis.
5. If continuing from a backup, click **Import**, select the exported analysis JSON file and complete the import. An imported analysis with an existing ID is added as a separate imported copy.

The tool stores analyses in the browser's local storage. **Save** stores the current work locally; it does not download a backup. Use **Export** regularly and keep the JSON file in your project's document storage. Browser-data deletion, a different browser profile or a different site address can make the locally stored analysis unavailable.

Finish and save an open form before switching analyses or exporting. Several tab controls save changes immediately, but an unfinished dialog is not a substitute for a saved entry.

Some features load external libraries, particularly PDF generation and tree rendering. If these are unavailable, see the troubleshooting section.

Recommended workflow: Overview → Settings → Assets → Damage scenarios → Risk analysis → Risk Lifecycle → Security goals → Residual risk → CRA Documentation Checklist → final review and export. Use **Parameters** whenever you need a field definition.

2. Define the scope in Overview

1. Enter the **Analysis name** and **Author / responsible person**.
2. Add the two optional images below these fields: the system/product architecture, and internal components/external interfaces. Use PNG, JPEG or WebP, up to **5 MB per image**. Large images are optimised for storage. Check that diagram labels remain readable in the resulting report.
3. Complete the fields in the following order. Use **Add item** for each separate list entry.

Field	What to enter	Example
System description	System boundary, architecture, interfaces and dependencies.	A controller connected to a customer OT network and a maintenance laptop.
Functions	One function per list item.	Receive commands; control an actuator; install firmware updates.
Intended use	Users, environment and permitted operation.	Trained technicians service the controller in an access-controlled production area.
Potential misuse cases	One foreseeable misuse per item.	Connect the service interface to an unmanaged network.
Product variants evaluated	One explicitly covered variant per item.	Model A, Ethernet interface, firmware 2.x.
Assumptions	One assessment assumption per item.	The customer separates the OT network from the public internet.

- Click **Save** in the analysis header.
- Check that the scope is precise enough to decide which assets and interfaces belong in the assessment.

The two description fields accept paragraphs. The other four fields are lists so functions, variants, misuse cases and assumptions stay distinct. The overview text, lists and images are included in the analysis PDF.

3. Agree assessment settings

Open **Settings** in the top bar while the correct analysis is selected.

Set the SL-T targets

Select a target separately for each of the seven requirements shown in the tool:

Requirement	Name in the tool	Decision to discuss
FR1 / IAC	Identification and authentication control	Required confidence in user, device and service identities.
FR2 / UC	Use control	Required control over permitted actions and privileges.
FR3 / SI	System integrity	Required protection against unauthorised changes.
FR4 / DC	Data confidentiality	Required protection against disclosure.
FR5 / RDF	Restricted data flow	Required restrictions on communication.
FR6 / TRE	Timely response to events	Required detection and response capability.
FR7 / RA	Resource availability	Required continuity of essential resources and services.

Each target accepts **Not set** or **0–4**. Not set means no decision has been recorded; 0 is an explicit selected target. Use **Parameters** → **Settings** → **SL-T targets** for the level summaries. Agree the targets with the relevant product and security stakeholders and record the rationale in the analysis documentation.

SL-T represents the intended protection. The seven targets stay separate and do not decrease automatically when a mitigation reduces a risk score.

Configure the residual SL matrix

1. Enter three positive, increasing boundaries for **Attack feasibility** and three for **Impact**. These create four bands for each axis. A value exactly on a boundary belongs to the lower band.
2. Use feasibility based on the tool's **K + S + T + U** score. The impact axis uses the normalised numerical impact; its boundaries are not the damage matrix's Low/Medium/High dropdown values.
3. Select **SL 0–4** for each of the 16 matrix cells, using your agreed company mapping.
4. Click **Save settings**.

An incomplete matrix can be saved, but it cannot produce a residual SL result. The displayed **SL-C planning estimate** is a configurable lookup result; it does not demonstrate implemented security capability. Risk analysis does not display SL-C. Residual risk displays the estimate and the shared SL-T targets.

Settings belong to the selected analysis. General K/S/T/U choices and other scoring defaults come from the separate assessment configuration. Use **Overview** → **Load assessment config** only when applying an agreed company configuration. That load affects the running session and can change recalculated results; it is not an analysis import.

4. Register and evaluate assets

1. Open **Assets** and click **Add asset**.
2. Enter a clear, unique **Name** and choose a **Type**.

3. Describe the asset's role, boundary, interfaces and relevant assumptions.
4. Assess all five protection properties individually.
5. Click **Save**. Repeat for the other assets in scope.

Type	Typical entries
Component	Hardware, controllers, communication interfaces.
Data	Software, firmware, configuration data, cryptographic keys.
Function	Internal functions and system functions.

Choose I, II or III by the consequences of a failure

The **Parameters** tab contains editable proposed definitions. As a starting point, **I** means limited consequences, **II** significant consequences, and **III** severe consequences. These are protection-need categories, distinct from the SL-T values in Settings.

Property	Question to ask	Illustrative progression from I to III
Confidentiality	What happens if someone learns the information?	Limited disclosure of internal information → sensitive business disclosure → exposure of a signing key or fleet administrator credentials.
Integrity	What happens if the asset is changed without permission?	Correctable display error → production rework → dangerous control behaviour.
Availability	What happens if the asset stops working?	Workaround available → significant production interruption → essential service lost beyond the tolerable outage.
Authentication	What happens if a false identity is trusted?	Low-consequence viewer impersonation → machine maintenance impersonation → trusted update service impersonation.
Authorization	What happens if someone exceeds their permissions?	Minor preference change → unauthorised machine settings → broad administrative control or bypass of critical safeguards.

Authentication asks **“Who is this?”** Authorization asks **“What may this identity do?”** Assess both even when the same interface is involved.

Select the highest credible consequence for each property in the assessed context. An example does not automatically determine the level. Record the reasoning in the asset description. I still means protection is needed. **N/A** is available for Authentication and Authorization when a criterion does not apply; explain why. Leaving a selection blank means it has not been evaluated.

The tool derives an overall protection need from the highest selected property. Complete the individual assessment rather than relying on an automatically displayed result.

5. Rate damage scenarios and explain every cell

Open **Damage scenarios** after adding assets. The matrix has assets as rows and damage scenarios as columns. Column headers remain visible as you scroll.

The default scenarios are:

ID	Scenario	Assessment focus
DS1	Danger to life and limb	Harm to people.
DS2	Financial damage	Direct or indirect financial losses.
DS3	Operation damage	Loss of operation in the component.
DS4	Loss of privacy/data	Loss or disclosure of sensitive data.
DS5	Legal consequences	Consequences of violations relevant to the assessed product.

To add a custom scenario, click **New**, enter its name, a short description of at most 10 characters, and an optional explanation; then save. Describe a harmful outcome, rather than an attack technique.

For **every asset/scenario pair**:

1. Decide whether that harmful outcome is applicable to the asset.
2. Select **Low**, **Medium**, **High** or **N/A** in the matrix cell.
3. Click the cell's ... comment control.
4. Explain the outcome, the selected severity, assumptions and available evidence. Save the comment.
5. Review the missing-comment indications before moving on.

Rating	General interpretation	DS3 example
Low / 1	Limited, local harm, recoverable through routine procedures or a practical workaround.	A nonessential interface stops, while the component remains usable through another interface.
Medium / 2	Significant but contained disruption requiring dedicated recovery or rework.	A component stops one production cell until specialist recovery.
High / 3	Severe, widespread or difficult-to-reverse harm.	An essential process stops without a workable fallback beyond the agreed tolerable outage.
N/A	The stated damage is not applicable in the assessed context.	A scenario concerns records that the component neither stores nor handles.

Use company-specific thresholds for duration, affected people, financial loss and data sensitivity. Rate the **consequence**, not the likelihood of an attack. N/A is not “low” or “unknown”; an untouched cell also displays N/A, so make the decision explicit in the comment.

Every cell requires a comment, including N/A. Missing comments block the analysis PDF export.
Comments are included in that report.

6. Create risks and attack paths

Risks are created manually. A matrix rating does not automatically create a risk. Each risk is assigned to **one asset**, and every attack path within it refers to that asset.

1. Open **Risk analysis** and review the asset coverage list. Identify assets with no attached risk or with insufficiently explored attack paths.
2. Use **Create risk** for the relevant asset, or open the new-risk form and select its **Asset**.
3. Read the **Damage Scenario impact** preview in the form. It shows the ratings already assigned to that asset.
4. Enter the **Attack goal / root**, describing the attacker's intended outcome.
5. Add an **Attack path**, describing how that outcome could be reached. Add intermediate paths if they help explain the sequence.
6. Add an **Impact** leaf for the concrete harmful result.
7. Tick the damage scenarios relevant to that leaf. At least one linked scenario with an applicable numeric rating is needed for a calculated impact.
8. Select all four **K, S, T and U** values for each leaf.
9. Use the path/impact note controls for assumptions, evidence and reasoning. Use whole-risk notes for information applying to the entire risk.
10. Save and close the risk editor. Review the resulting risk and the asset coverage list.

What to enter for K, S, T and U

The following values are the shipped defaults. If your organisation loads a different configuration, follow the current dropdowns and **Parameters** reference.

Factor	What to assess	Default choices
K — Complexity / knowledge	Knowledge and discovery effort needed for the attack.	0.7 known vulnerabilities; 0.6 simple internet research; 0.3 expert research; 0.1 expert knowledge.
S — Scaling	Scope in which the attack can spread or be repeated.	0.5 customer IT network; 0.3 customer OT network; 0.1 single product/local machine.
T — Time / effort	Effort to prepare and execute the attack under the stated conditions.	0.5 under 1 week; 0.4 under 4 weeks; 0.2 under 3 months; 0.1 over 3 months.
U — Utility	Visible benefit or incentive for the attacker.	0.5 high; 0.3 medium; 0.1 low.

Larger factors increase the feasibility score; they are not percentages. For overlapping time descriptions, use the most specific applicable choice, and agree how your company treats exact boundaries.

Read the results correctly

The tool combines the assigned asset's protection need with the linked damage ratings. It does not average ratings from all assets. For multiple linked scenarios it uses the highest resulting impact. Parent paths and the root inherit worst-case impact and K/S/T/U values, so a root can combine maxima from different leaves.

The score is $R = \text{normalised impact} \times (K + S + T + U)$. Scores and classes are outputs; enter the supporting assessment in the leaf fields. An unknown result or an empty leaf needs review. A scored root does not prove that every path is complete.

If one attack affects several assets, create separate asset-linked risks as needed and cross-reference them in notes. When an asset or damage rating changes, review its associated risks and subsequent residual decisions.

7. Assign lifecycle phases

1. Open **Risk Lifecycle** after creating the risks.
2. For each risk, open **Select phases** and select every phase in which it is most relevant.
3. Choose from design and development, procurement, manufacturing and assembly, testing and quality assurance, storage and transport, installation and commissioning, operation, maintenance and updates, and decommissioning and disposal.
4. If needed, select **Custom phase** and enter its name.
5. Add **Reason / notes** explaining the selection.

More than one phase can be assigned to the same risk. For example, malicious firmware installation can be relevant during manufacturing, commissioning and maintenance. An unnamed custom phase is incomplete as a named assignment.

Lifecycle assignments organise review responsibilities and timing. They do not change the calculated score. The assignments and notes are included in the analysis PDF.

8. Define security goals

1. Open **Security goals** and click **Add security goal**.
2. Enter a goal name describing the required security outcome.
3. Use the description to explain scope, expected behaviour and how the outcome will be verified.
4. Tick one or more referenced risks/attack goals.
5. Save and repeat as needed.

Example goal: "Only authorised firmware may execute."

Description: "Verify firmware origin and integrity before installation and startup. Reject untrusted packages and retain the verification test evidence."

A goal may address several risks, and a risk may have several goals. These links can also be maintained in the Residual risk editor. Linking a goal records the relationship; it does not automatically lower a score.

9. Evaluate residual risks

1. Open **Residual risk** and edit the relevant risk.
2. Choose a treatment for **each impact leaf**.
3. Complete the associated Notes, **Detailed Control Measure** and reassessment fields as required by the treatment.
4. If at least one impact is **Mitigated**, the **Security goals** selector appears at the bottom of the editor. Select the relevant goals there; create missing goals in the Security goals tab first.
5. Finish the editor using **Done**.
6. On the risk card, review the same Notes value and the remaining score.
7. Mark the risk **evaluated** after the review is complete.

Treatment	What you must document	Effect on the assessment
Accepted	Rationale for retaining the risk and the supporting decision.	Original K/S/T/U remain in use.
Delegated	Who will handle it, the responsibility boundary and supporting evidence.	Original K/S/T/U remain in use.
Mitigated	Concrete Detailed Control Measure and all four reassessed K/S/T/U values.	Reassessed factors are used for this leaf.

For Accepted and Delegated leaves, the shared Notes field is required for the completion indicator. For Mitigated leaves, the Detailed Control Measure and all four factors are required. If a residual factor is missing, the calculation can fall back to its original value; a displayed score therefore does not guarantee a completed reassessment.

Use the optional **Link to requirement** field directly beneath each **Detailed Control Measure** to enter a requirement URL or ID, such as REQ-SEC-012. It is editable when the impact is Mitigated, shared between display languages, saved with the assessment and included beneath the measure in the PDF report. It does not affect the score or completion indicator.

Reassess only changes supported by the measure and evidence. The residual calculation retains the impact; it changes the attack feasibility factors. Selecting “Mitigated” by itself does not reduce the risk.

There is **one Notes value per residual risk**, shared by the edit window and the overview card. Editing or clearing either field immediately updates the other. The editor shows one Notes field across its impact rows. Use it to explain the relevant treatment decisions and the overall review. Existing differing notes from older analyses are combined once, retaining distinct text without duplicating identical entries.

The same Notes field is also required for completion when the remaining class is **High** or **Critical**. Use it to record the decision, remaining limitations and follow-up actions.

The **evaluated** checkbox is a manual review status, separate from field completeness. It does not validate the evidence, approve acceptance or change a score. Revisit it when the underlying assessment changes.

If configured, the card also displays the residual **SL-C planning estimate** and the analysis's **SL-T** targets. Treat these as different concepts: a lower lookup result after mitigation does not lower the chosen target or prove a change in implemented capability.

10. Review CRA documentation

Open **CRA Documentation Checklist** to track the documentation review organised under **Annex V** and **Annex VII**.

1. Read each item and locate the relevant document or evidence.
2. Add a comment, a reference link, or both. Useful comments identify the document version, reviewer, outstanding action or applicability reasoning.
3. Use a complete `https://` or `http://` URL when you want the link to open from the tool.
4. Tick the item when your review of it is complete.
5. For conditional items that do not apply, record the reason in the comment.

The counters track reviewed checklist items, rather than establishing product conformity. Clearing a checkmark preserves its comment and link. The checklist is saved with the analysis and included in JSON exports and version snapshots.

The CRA Documentation Checklist is excluded from the analysis PDF. Retain the JSON backup and the referenced evidence for this part of the work.

11. Use the Parameters reference

1. Open the final **Parameters** tab.
2. Follow a section link for the relevant tab/window, or search for a field, value or example.
3. Read what the field requires, the meaning of its possible values and the examples.
4. Return to the relevant entry window to fill in the assessment.

The guide covers 51 user-entered fields, grouped by their actual tab and dialog. It includes the proposed I/II/III protection levels and damage impact interpretations, which can be discussed and adapted to company needs. Current configurable choices are drawn from the active assessment configuration.

Parameters is a reference, not an additional entry form. It is not an analysis PDF chapter.

12. Save versions and export deliverables

Save a review milestone

1. Finish open forms and click **Save** in the analysis header.
2. Open **Versions** → **New version**.

3. Choose **Incremental** for the next minor version or **Major** for a new major version.
4. Enter the required comment describing what changed and why.
5. Save the version.

Versions store snapshots of the analysis. **Restore** replaces the working state with the selected snapshot after confirmation. Export a JSON backup first if you need to keep the current working state separately.

Download an editable backup

1. Select the correct analysis and click **Save**.
2. Click **Export** in the top bar.
3. Store the downloaded JSON with the project's review records.
4. To resume elsewhere, use **Import** in the other browser and select this JSON.

The export contains the selected analysis, including its settings, checklist and history. Keep the company assessment configuration alongside it when that configuration has been customised; the running app's global scoring configuration is separate from the analysis data.

Generate the analysis PDF

1. Select the required display language and review the text in that language. Switching the interface does not automatically translate your own descriptions.
2. Complete every Damage scenarios matrix comment, including N/A cells.
3. Review the risk paths, goal links, lifecycle assignments, residual notes and evaluation status.
4. Open **Overview** and click **Report (PDF)**.
5. Open the downloaded PDF and check its name/version, images, matrix comments, risk details, security goals, lifecycle information and residual results/settings.

The report includes the analysis content and assessment results. It excludes the CRA checklist and Parameters reference. A successful export confirms that a report was generated; it does not establish that the assessment is complete or approved. The PDF is a review deliverable, while JSON is the editable backup.

Other exports and About

Overview → **Export tree data** provides tree data as a ZIP for further use. **About** → **Export SBOM** downloads the tool's own software bill of materials; it is not an inventory of your assessed product. Close About with ×, Escape or a click on the backdrop outside the window.

13. Worked example

Use the following as a practice exercise with the shipped scoring defaults. It describes a single risk against a fictional industrial controller; the ratings are illustrative assumptions.

1. **Overview:** Name the analysis "Controller A — maintenance interface". Describe a controller on a customer OT network. Add the assumption that maintenance access is restricted to trained technicians.

2. **Assets:** Add “Controller firmware” as **Data**. In this example, choose Confidentiality I, Integrity II, Availability II, Authentication II and Authorization II. State that incorrect firmware can stop one cell but, under the example’s system boundary, does not cause safety-critical behaviour. The overall protection need is II.
3. **Damage scenarios:** Rate this asset’s **DS3 Operation damage** as High under the example company’s outage threshold. Comment: “Firmware failure can stop the cell beyond its agreed maximum tolerable outage; no immediate replacement is available.” Deliberately assess and comment all other scenario cells too.
4. **Risk analysis:** Create a risk for that asset with the goal “Stop controller operation through an unauthorised update”. Add a path “Abuse the maintenance update interface” and an impact leaf “Controller cannot start”. Link DS3.
5. **Original factors:** Select K 0.7, S 0.1, T 0.5 and U 0.3. Record the example assumptions: known update weakness, one local controller affected, less than a week of effort and medium attacker benefit.
6. **Lifecycle:** Select installation and commissioning, and maintenance and updates. Explain that these phases expose the update workflow.
7. **Security goal:** Create “Reject unauthorised firmware” and link it to the risk.
8. **Residual risk:** Choose Mitigated. Describe signature verification, protected trust material and access control for the update process. Assuming verification evidence supports the reduction, reassess K as 0.1 and T as 0.2; leave S at 0.1 and U at 0.3. Explain the evidence and remaining assumptions.
9. **Review:** Add the whole-risk residual decision, verify the goal link, and mark evaluated when the review is complete. Save a version, export JSON and create the PDF after all matrix comments are present.

With the shipped factors, protection II contributes 0.8 and High severity contributes 1.0, so the normalised impact is **0.8**. The original score is $0.8 \times (0.7 + 0.1 + 0.5 + 0.3) = 1.28$, classified **Medium**. The example residual score is $0.8 \times (0.1 + 0.1 + 0.2 + 0.3) = 0.56$, classified **Low**.

These numbers change if the configuration or linked scenarios change. The example deliberately does not prescribe an SL-T target or residual SL matrix; those need the organisation’s agreed decisions.

14. Troubleshooting and final review

Symptom	What to check
PDF export reports missing comments	Open Damage scenarios and complete every cell's comment, including N/A.
A risk has no calculated impact	Confirm its asset, linked damage scenarios and at least one applicable numeric matrix rating.
A risk score is unknown or incomplete	Complete all four factors on each relevant leaf and check that its impact is assessed.
An asset has no attached risk	Use its Create risk action in Risk analysis; risks are not automatically generated from the matrix.
Residual score did not decrease	Check that the treatment is Mitigated and that supported reassessed factors were entered. Goals and status checkboxes do not lower scores.
Residual SL-C is not configured	Complete all 16 matrix cells and valid increasing boundaries in Settings; also check the underlying risk assessment.
Evaluated is checked but fields are missing	Review status is manual. Complete the required treatment fields and any High/Critical whole-risk note.
An image is rejected	Use PNG, JPEG or WebP within the 5 MB per-image limit.
PDF or tree rendering is unavailable	Check whether the required external libraries/services loaded and whether the network allows them. Preserve a JSON backup while resolving access.
Work is missing in another browser	Import the exported analysis JSON. Local browser storage is not shared project storage.
A language switch leaves text in the original language	Enter the appropriate text for that language where supported; user descriptions are not automatically translated.

Before handing the assessment to a reviewer, confirm:

- ☐ The scope, variants, assumptions and responsible person are clear.
- ☐ Assets and all five protection properties have been reviewed.
- ☐ Every damage matrix cell has a deliberate rating and supporting comment.
- ☐ Asset coverage and plausible attack paths have been reviewed.
- ☐ Relevant leaves have scenario links and complete K/S/T/U assessments.
- ☐ Lifecycle phases and security goals are linked to the appropriate risks.
- ☐ Residual treatments, measures, evidence, notes and review statuses are complete.
- ☐ SL-T and matrix settings reflect the agreed assessment approach, where used.
- ☐ CRA checklist comments/links point to the reviewed documentation.
- ☐ A milestone version, JSON backup and checked PDF report are available.

15. Maintain the guidance

The editable source of this document is `docs/user-guide.md`. The companion `docs/user-guide.pdf` is the formatted reading copy. Regenerate the PDF after changing the Markdown so both versions stay consistent.

For company-specific in-app guidance, edit `config/parameter_guide.js`. The `sections[].fields[]` entries contain descriptions and examples. The `interpretations[]` entries define I/II/III and damage rating guidance in English and German.

For actual scoring choices and defaults, edit `config/assessment_config.json`, then run `python3 scripts/sync_assessment_config.py` from the project root and reload the app. Changing explanatory text alone does not change scoring.

See `docs/parameters-customization.md` for exact field keys and source locations. The user workflow in this edition was checked against the current forms, guide definitions, analysis persistence, risk editors and report export code. Recheck the instructions when those behaviours change.